เอกสารประกอบการปฏิบัติการ
รายวิชา CP423324 Database and Web Security
Lab 12: Secure File Upload and Security Logging
(การอัปโหลดไฟล์และบันทึกเหตุการณ์ด้านความปลอดภัย)

วัตถุประสงค์

1. เพื่อให้นักศึกษาสามารถอธิบายความเสี่ยงของการอัปโหลดไฟล์ และตรวจสอบ Extension, MIME Type และขนาดไฟล์ได้
2. เพื่อให้นักศึกษาสามารถเปลี่ยนชื่อไฟล์ก่อนจัดเก็บ และเก็บไฟล์ไว้นอก Web Root เพื่อลดความเสี่ยงจากการรันไฟล์อันตรายได้
3. เพื่อให้นักศึกษาสามารถควบคุมสิทธิ์ในการดาวน์โหลดไฟล์ด้วย Role และ Ownership Check ได้
4. เพื่อให้นักศึกษาสามารถบันทึก Security Log สำหรับเหตุการณ์ Login, การแก้ไขข้อมูล และการอัปโหลดไฟล์ โดยไม่บันทึกข้อมูลลับได้

คำชี้แจง

1. ให้นักศึกษา Capture ผลลัพธ์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab12_รหัสนักศึกษา(มีขีด).pdf
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

★★★★★★★★★★

โจทย์ที่กำหนด

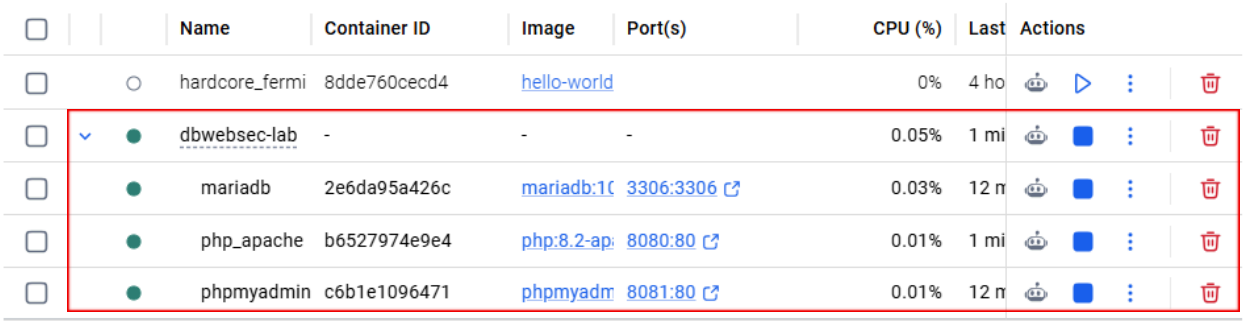
งานปฏิบัติการนี้พัฒนาต่อจาก Lab11 โดยยังใช้ฐานข้อมูล db_lab08 และตาราง user_profiles เดิม แต่เพิ่มโมดูลสำหรับอัปโหลดไฟล์และ Security Logging ใน Lab12 จะเปลี่ยนจากการสลับผู้ใช้แบบจำลองใน Lab11 มาเป็นหน้า Login สำหรับการทดสอบการบันทึกเหตุการณ์ LOGIN_SUCCESS และ LOGIN_FAILED แนวคิดหลักของ Lab12 คือ เปรียบเทียบ Insecure File Upload กับ Secure File Upload แล้วนำ Security Control จากบทก่อนหน้า ได้แก่ Session, Authorization, Ownership Check, CSRF Token, Input Validation และ Prepared Statement มาใช้ร่วมกัน

กำหนดสิทธิ์ของผู้ใช้งานระบบ

Role	Upload	ดู/ดาวน์โหลดไฟล์	Profile	Security Logs
user	ได้	เฉพาะไฟล์ของตนเอง	ดู/แก้ไขของตนเอง	ไม่ได้
admin	ได้	ไฟล์ของทุกคน	ดู/แก้ไขของตนเอง	ดูได้

มีขั้นตอนการพัฒนาระบบ ดังนี้

1. เปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab, mariadb, php_apache และ phpmyadmin



2. การใช้ฐานข้อมูลชื่อ db_lab08 และตาราง user_profiles จาก Lab11 ต่อเนื่อง โดยเพิ่มตาราง uploaded_files และ security_logs ซึ่งมีรายละเอียดของตาราง ดังนี้

โครงสร้างของตาราง uploaded_files

Field	Data Type	ข้อกำหนด	ความหมาย
id	INT	PRIMARY KEY, AUTO_INCREMENT	รหัสไฟล์
original_name	VARCHAR(255)	NOT NULL	ชื่อไฟล์เดิมจากผู้ใช้
stored_name	VARCHAR(100)	NOT NULL, UNIQUE	ชื่อไฟล์ใหม่ที่ Server ตั้งให้
mime_type	VARCHAR(100)	NOT NULL	MIME Type ที่ตรวจจากไฟล์จริง
file_size	INT UNSIGNED	NOT NULL	ขนาดไฟล์เป็น byte
uploaded_by	VARCHAR(50)	NOT NULL	ผู้ที่อัปโหลดไฟล์
storage_type	VARCHAR(20)	NOT NULL DEFAULT 'secure',	รูปแบบการจัดเก็บไฟล์ คือ secure หรือ insecure
uploaded_at	DATETIME	DEFAULT CURRENT_TIMESTAMP	วันเวลาที่อัปโหลด

ตัวอย่างคำสั่ง SQL

สร้างตาราง uploaded_files

```
CREATE TABLE uploaded_files (
    id INT AUTO_INCREMENT PRIMARY KEY,
    original_name VARCHAR(255) NOT NULL,
    stored_name VARCHAR(100) NOT NULL UNIQUE,
    mime_type VARCHAR(100) NOT NULL,
    file_size INT UNSIGNED NOT NULL,
    uploaded_by VARCHAR(50) NOT NULL,
    storage_type VARCHAR(20) NOT NULL DEFAULT 'secure',
    uploaded_at DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP
```

) CHARACTER SET utf8mb4

COLLATE utf8mb4_unicode_ci;

ผลลัพธ์จากการสร้างตาราง uploaded_files ดังนี้

#	Name	Type	Collation	Attributes	Null	Default	Comments	Extra
1	**id**	int(11)			No	*None*		AUTO_INCREMENT
2	**original_name**	varchar(255)	utf8mb4_unicode_ci		No	*None*		
3	**stored_name**	varchar(100)	utf8mb4_unicode_ci		No	*None*		
4	**mime_type**	varchar(100)	utf8mb4_unicode_ci		No	*None*		
5	**file_size**	int(10)		UNSIGNED	No	*None*		
6	**uploaded_by**	varchar(50)	utf8mb4_unicode_ci		No	*None*		
7	**storage_type**	varchar(20)	utf8mb4_unicode_ci		No	secure		
8	**uploaded_at**	datetime			No	current_timestamp()		

โครงสร้างของตาราง security_logs

Field	Data Type	ข้อกำหนด	ความหมาย
id	BIGINT	PRIMARY KEY, AUTO_INCREMENT	รหัส Log
username	VARCHAR(50)	NULL	ผู้ใช้หรือ Username ที่พยายาม Login
event_type	VARCHAR(50)	NOT NULL	ชนิดเหตุการณ์
status	VARCHAR(20)	NOT NULL	SUCCESS / FAILED
ip_address	VARCHAR(45)	NOT NULL	IP Address ของ Client
details	VARCHAR(255)	NOT NULL	รายละเอียดที่ไม่ใช่ข้อมูลลับ
created_at	DATETIME	DEFAULT CURRENT_TIMESTAMP	วันเวลาที่เกิดเหตุการณ์

ตัวอย่างคำสั่ง SQL

สร้างตาราง security_logs

```
CREATE TABLE IF NOT EXISTS security_logs (
    id BIGINT AUTO_INCREMENT PRIMARY KEY,
    username VARCHAR(50) NULL,
    event_type VARCHAR(50) NOT NULL,
    status VARCHAR(20) NOT NULL,
    ip_address VARCHAR(45) NOT NULL,
    details VARCHAR(255) NOT NULL,
    created_at DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP
) CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;
```

ผลลัพธ์จากการสร้างตาราง security_logs ดังนี้

#	Name	Type	Collation	Attributes	Null	Default	Comments	Extra
1	id	bigint(20)			No	None		AUTO_INCREMENT
2	username	varchar(50)	utf8mb4_unicode_ci		Yes	NULL		
3	event_type	varchar(50)	utf8mb4_unicode_ci		No	None		
4	status	varchar(20)	utf8mb4_unicode_ci		No	None		
5	ip_address	varchar(45)	utf8mb4_unicode_ci		No	None		
6	details	varchar(255)	utf8mb4_unicode_ci		No	None		
7	created_at	datetime			No	current_timestamp()		

กำหนดสิทธิ์ของ webapp_user ตามหลัก Least Privilege ดังนี้

```
GRANT SELECT, INSERT
ON db_lab08.uploaded_files
TO 'webapp_user'@'%';

GRANT SELECT, INSERT
ON db_lab08.security_logs
TO 'webapp_user'@'%';
```

ตรวจสอบสิทธิ์ด้วยคำสั่งนี้

```
SHOW GRANTS FOR 'webapp_user'@'%';
```

หมายเหตุ: สิทธิ์ SELECT ของ security_logs จำเป็นสำหรับหน้า Admin ที่ใช้ Database Account เดียวกัน แต่การจำกัดว่าสามารถเปิดหน้า Log ได้จะบังคับด้วย Server-side Authorization ใน Web Application

3. เตรียมโฟลเดอร์สำหรับเก็บไฟล์

สร้างโฟลเดอร์ uploads_lab12 ไว้นอกโฟลเดอร์ www เช่น C:\dbwebsec-lab\uploads_lab12 แล้วเพิ่ม Volume ให้ service web ใน docker-compose.yml

```
services:
    web:
        volumes:
         - ./www:/var/www/html
        - ./uploads_lab12:/var/www/uploads_lab12
```

```yaml
services:
  web:
    build: .
    container_name: php_apache
    ports:
      - "8080:80"
    volumes:
      - ./www:/var/www/html
      - ./uploads_lab12:/var/www/uploads_lab12
    environment:
      TZ: Asia/Bangkok
      TURNSTILE_SITE_KEY: ${TURNSTILE_SITE_KEY}
      TURNSTILE_SECRET_KEY: ${TURNSTILE_SECRET_KEY}
```

จากนั้น Restart Container เพื่อให้ Volume ใหม่มีผล ส่วนโฟลเดอร์ uploads_insecure จะถูกสร้างภายใน C:\dbwebsec-lab\www\Lab12 เพื่อใช้สาธิตความเสี่ยงจากการเก็บไฟล์ใน Web Root

การ Restart Container ให้เปิด CMD พิมพ์คำสั่ง ดังนี้

cd C:\dbwebsec-lab

docker compose down

docker compose up -d

4. การสร้างเว็บแอปพลิเคชัน

ให้นักศึกษาสร้างโฟลเดอร์ Lab12 ไว้ภายใน C:\dbwebsec-lab\www สำหรับไฟล์ที่ต้องสร้างมีไฟล์ทั้งหมด 11 ไฟล์ มีรายละเอียด ดังนี้

1) Lab12_config.php สำหรับเชื่อมต่อฐานข้อมูล จัดการ Session/CSRF Token กำหนด Demo Account, Authorization Helper และ security_log()
2) Lab12_login.php สำหรับตรวจสอบการ Login และบันทึก LOGIN_SUCCESS หรือ LOGIN_FAILED
3) Lab12_logout.php สำหรับออกจากระบบด้วย POST + CSRF และบันทึกเหตุการณ์ Logout
4) Lab12_upload_insecure.php สำหรับตัวอย่างการอัปโหลดไฟล์ที่ยังไม่มีการตรวจสอบด้านความปลอดภัย
5) Lab12_upload_form.php สำหรับหน้า Form อัปโหลดไฟล์อย่างปลอดภัย
6) Lab12_upload_secure.php สำหรับตรวจ Size, Extension, MIME Type, เปลี่ยนชื่อไฟล์ และจัดเก็บนอก Web Root อย่างปลอดภัย (นักศึกษาสร้างเอง)
7) Lab12_files.php สำหรับแสดงรายการไฟล์ที่ผู้ใช้มีสิทธิ์เข้าถึง และเมนูสำหรับจัดการ
8) ไฟล์Lab12_download.php สำหรับดาวน์โหลดไฟล์ผ่าน Endpoint หลังตรวจ Role และ Ownership
9) Lab12_profile.php สำหรับแก้ไข Profile ของผู้ใช้และบันทึก PROFILE_UPDATE
10) Lab12_security_logs.php เป็นหน้าเฉพาะ Admin สำหรับตรวจสอบ Security Log ของระบบ
11) malicious_demo.php (เตรียมไว้ให้สำหรับใช้เฉพาะใน Lab นี้เท่านั้น)

หมายเหตุ: Lab12 ใช้ Demo Account ที่กำหนดไว้ใน Lab12_config.php เพื่อสาธิต Login และ Security Logging โดยไม่ได้เน้นการพัฒนาระบบ Authentication จากฐานข้อมูล

รายละเอียดของแต่ละไฟล์ ดังนี้

4.1 การสร้างไฟล์ Lab12_config.php โดยมีคำสั่ง ดังนี้

```php
<?php
declare(strict_types=1);

session_start();
date_default_timezone_set('Asia/Bangkok');

const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_lab08';
const DB_USER = 'webapp_user';
const DB_PASS = 'WebApp1234';

const SECURE_UPLOAD_DIR = '/var/www/uploads_lab12';
const MAX_UPLOAD_SIZE = 2 * 1024 * 1024; // 2 MB

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);

try {
    $conn = new mysqli(DB_HOST, DB_USER, DB_PASS, DB_NAME, DB_PORT);
    $conn->set_charset('utf8mb4');
    $conn->query("SET time_zone = '+07:00'");
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Database connection failed.');
}

function h(?string $value): string
{
    return htmlspecialchars($value ?? '', ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
}

function text_length(string $value): int
{
    return function_exists('mb_strlen')
        ? mb_strlen($value, 'UTF-8')
        : strlen($value);
}

if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}

```

```php
/*
 * Demo accounts for Lab12 only.
 * In a real application, store password hashes and roles in the database.
 */
$demoAccounts = [
    'student01' => [
        'role' => 'user',
        'password_hash' => '$2y$12$.JJKqDNE5/H0lCSPVCEMherUXkgHJnVFkolZJiro8dGWVlvjUx.Ie',
    ],
    'student02' => [
        'role' => 'user',
        'password_hash' => '$2y$12$BVsHtWGFEJ.KgNu5Ir0oUeWvkcrBGgEmJSbxgKFg2GI9uPWn0CmM2',
    ],
    'admin01' => [
        'role' => 'admin',
        'password_hash' => '$2y$12$4i.eMAkXh39Roc0U5wPEkOjGam4Dk/STVVStGwHj08M1hAFLAlBMi',
    ],
];

$currentUser = $_SESSION['username'] ?? null;
$currentRole = $_SESSION['role'] ?? null;

function require_login(): void
{
    if (empty($_SESSION['username']) || empty($_SESSION['role'])) {
        http_response_code(401);
        exit('Authentication required.');
    }
}

function is_admin(?string $role): bool
{
    return $role === 'admin';
}

function verify_csrf_token(): void
{
    $token = $_POST['csrf_token'] ?? '';

    if (
        !is_string($token) ||
        !isset($_SESSION['csrf_token']) ||
        !hash_equals($_SESSION['csrf_token'], $token)
    ) {
        http_response_code(403);
        exit('Invalid request.');
    }
}

function client_ip(): string
{
    return $_SERVER['REMOTE_ADDR'] ?? 'unknown';
}

```

```php
function security_log(
    mysqli $conn,
    ?string $username,
    string $eventType,
    string $status,
    string $details = ''
): void {
    $ip = client_ip();

    $stmt = $conn->prepare(
        'INSERT INTO security_logs
            (username, event_type, status, ip_address, details)
         VALUES (?, ?, ?, ?, ?)'
    );
    $stmt->bind_param('sssss', $username, $eventType, $status, $ip, $details);
    $stmt->execute();
}
```

4.2 Lab12_login.php สำหรับตรวจสอบการ Login และบันทึก LOGIN_SUCCESS หรือ LOGIN_FAILED โดยมีคำสั่ง ดังนี้

```php
<?php
require_once 'Lab12_config.php';
if (!empty($_SESSION['username']) && !empty($_SESSION['role'])) {
    header('Location: Lab12_files.php');
    exit;
}
$error = '';
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf_token();
    $username = trim($_POST['username'] ?? '');
    $password = $_POST['password'] ?? '';
    if (
        isset($demoAccounts[$username]) &&
        password_verify($password, $demoAccounts[$username]['password_hash'])
    ) {
        session_regenerate_id(true);
        $_SESSION['username'] = $username;
        $_SESSION['role'] = $demoAccounts[$username]['role'];
        $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
        security_log(
            $conn,
            $username,
            'LOGIN_SUCCESS',
            'SUCCESS',
            'Login successful'
        );
        header('Location: Lab12_files.php');
        exit;
    }
```

```
30      security_log(
31          $conn,
32          $username !== '' ? $username : null,
33          'LOGIN_FAILED',
34          'FAILED',
35          'Invalid username or password'
36      );
37      $error = 'Invalid username or password.';
38  }
39  ?>
40  <!doctype html>
41  <html lang="en">
42  <head>
43      <meta charset="utf-8">
44      <title>Lab12 Login</title>
45      <style>
46          body{
47              font-family:Arial,sans-serif;
48              max-width:900px;
49              margin:32px auto;
50              padding:0 16px;
51              line-height:1.5
52          }
53          .card{
54              max-width:460px;
55              border:1px solid #ccc;
56              border-radius:6px;
57              padding:18px;
58          }
59          label{
60              display:block;
61              font-weight:bold;
62              margin-top:10px;
63          }
```

```
        input[type=text],
        input[type=password]{
            width:100%;
            box-sizing:border-box;
            padding:8px;
        }
        button,.button-link{
            display:inline-flex;
            align-items:center;
            justify-content:center;
            min-width:90px;
            height:36px;
            padding:0 12px;
            border:1px solid #888;
            border-radius:4px;
            background:#f5f5f5;
            color:#111;
            text-decoration:none;
            cursor:pointer;
            box-sizing:border-box;
            font:inherit;
        }
        .actions{
            display:flex;
            gap:8px;
            margin-top:16px;
            align-items:center;
        }
        .notice{
            border:1px solid #ccc;
            border-radius:6px;
            padding:10px 12px;
            margin-bottom:14px;
        }
        .hint{
            color:#555;
            font-size:0.95em;
        }
    </style>
</head>
```

```
104   <body>
105   <h1>Lab12 Login</h1>
106   <p><strong>Secure File Upload and Security Logging</strong></p>
107   <?php if ($error !== ''): ?>
108       <div class="notice"><?= h($error) ?></div>
109   <?php endif; ?>
110   <section class="card">
111       <form method="post">
112           <label for="username">Username</label>
113           <input type="text" name="username" id="username" required>
114
115           <label for="password">Password</label>
116           <input type="password" name="password" id="password" required>
117           <input type="hidden"
118                  name="csrf_token"
119                  value="<?= h($_SESSION['csrf_token']) ?>">
120           <div class="actions">
121               <button type="submit">Login</button>
122           </div>
123       </form>
124   </section>
125   <p class="hint">
126       Demo accounts: student01 / Student01!,
127       student02 / Student02!, admin01 / Admin01!
128   </p>
129   </body>
130   </html>
```

4.3 Lab12_logout.php สำหรับออกจากระบบด้วย POST + CSRF และบันทึกเหตุการณ์ Logout โดยมีคำสั่งดังนี้

```
1   <?php
2   require_once 'Lab12_config.php';
3   require_login();
4   if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
5       http_response_code(405);
6       exit('Method not allowed.');
7   }
8   verify_csrf_token();
9   security_log(
10      $conn,
11      $currentUser,
12      'LOGOUT',
13      'SUCCESS',
14      'Logout'
15  );
16  $_SESSION = [];
```

```php
if (ini_get('session.use_cookies')) {
    $params = session_get_cookie_params();
    setcookie(
        session_name(),
        '',
        time() - 42000,
        $params['path'],
        $params['domain'],
        $params['secure'],
        $params['httponly']
    );
}
session_destroy();
header('Location: Lab12_login.php');
exit;
```

4.4 Lab12_upload_insecure.php สำหรับตัวอย่างการอัปโหลดไฟล์ที่ยังไม่มีการตรวจสอบด้านความปลอดภัย โดยมีคำสั่ง ดังนี้

```php
<?php
require_once 'Lab12_config.php';
require_login();
$message = '';
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $file = $_FILES['upload'] ?? null;
    if ($file && $file['error'] === UPLOAD_ERR_OK) {
        $uploadDir = __DIR__ . '/uploads_insecure';
        if (!is_dir($uploadDir)) {
            mkdir($uploadDir, 0755, true);
        }
        // INSECURE: trust the original file name from the client.
        $originalName = basename($file['name']);
        $targetPath = $uploadDir . '/' . $originalName;

                $message = 'Uploaded and metadata saved: ' . $originalName;
            } catch (Throwable $e) {
                error_log($e->getMessage());
                $message = 'File uploaded, but metadata could not be saved.';
            }
        } else {
            $message = 'Upload failed.';
        }
    } else {
        $message = 'Upload failed.';
    }
}
?>
```

```php
        // INSECURE: no CSRF, no extension check, no MIME check, no size check.
        if (move_uploaded_file($file['tmp_name'], $targetPath)) {
            /*
             * บันทึก Metadata ลงฐานข้อมูลด้วย
             * หมายเหตุ: ตัวอย่าง Insecure นี้เชื่อ MIME Type จาก Client
             * และใช้ชื่อไฟล์เดิมเป็น stored_name
             */
            $clientMimeType = (string)($file['type'] ?? 'application/octet-stream');
            $fileSize = (int)$file['size'];
            $storageType = 'insecure';
            try {
                $stmt = $conn->prepare(
                    'INSERT INTO uploaded_files
                        (original_name, stored_name, mime_type, file_size,
                         uploaded_by, storage_type)
                     VALUES (?, ?, ?, ?, ?, ?)'
                );
                $stmt->bind_param(
                    'sssiss',
                    $originalName,
                    $originalName,
                    $clientMimeType,
                    $fileSize,
                    $currentUser,
                    $storageType
                );
                $stmt->execute();

```

```html
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Lab12 - Insecure Upload</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            padding: 0 16px;
            line-height: 1.5
        }
        .card,
        .notice {
            border: 1px solid #ccc;
            border-radius: 6px;
            padding: 16px;
            margin-bottom: 16px
        }
        .warning {
            font-weight: bold
        }
```

```
        .actions,
        .nav-actions {
            display: flex;
            gap: 8px;
            margin-top: 12px;
            align-items: center;
            flex-wrap: wrap
        }
        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            min-width: 90px;
            height: 36px;
            padding: 0 12px;
            border: 1px solid #888;
            border-radius: 4px;
            background: #f5f5f5;
            color: #111;
            text-decoration: none;
            cursor: pointer;
            box-sizing: border-box;
            font: inherit
        }
    </style>
</head>
<body>
    <h1>Insecure File Upload</h1>
    <p>
        Current user: <strong><?= h($currentUser) ?></strong>
        | Role: <strong><?= h($currentRole) ?></strong>
    </p>
    <div class="nav-actions">
        <a class="button-link" href="Lab12_files.php">Back to Secure Files</a>
    </div>
    <div class="notice warning">
        This page is intentionally vulnerable for local classroom testing only.
    </div>
    <?php if ($message !== ''): ?>
        <div class="notice"><?= h($message) ?></div>
    <?php endif; ?>
    <section class="card">
        <h2>Upload File</h2>
        <form method="post" enctype="multipart/form-data">
            <input type="file" name="upload" required>
            <div class="actions">
                <button type="submit">Upload</button>
            </div>
        </form>
    </section>
    <p>
        This version intentionally does not check CSRF Token, extension,
        MIME Type, file size, or safe storage location.
    </p>
</body>
</html>
```

4.5 Lab12_upload_form.php สำหรับหน้า Form อัปโหลดไฟล์อย่างปลอดภัย โดยมีคำสั่ง ดังนี้

```php
<?php
require_once 'Lab12_config.php';
require_login();
?>
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Lab12 - Secure Upload</title>
    <style>
        body{
            font-family:Arial,sans-serif;
            max-width:900px;
            margin:32px auto;
            padding:0 16px;
            line-height:1.5
        }
        .card{
            border:1px solid #ccc;
            border-radius:6px;
            padding:16px;
            margin-bottom:16px
        }
        .actions,.nav-actions{
            display:flex;
            gap:8px;
            margin-top:12px;
            align-items:center;
            flex-wrap:wrap
        }
        button,.button-link{
            display:inline-flex;
            align-items:center;
            justify-content:center;
            min-width:90px;
            height:36px;
            padding:0 12px;
            border:1px solid #888;
            border-radius:4px;
            background:#f5f5f5;
            color:#111;
            text-decoration:none;
            cursor:pointer;
            box-sizing:border-box;
            font:inherit
        }
```

```
47          .meta{color:#666}
48      </style>
49  </head>
50  <body>
51  <h1>Secure File Upload</h1>
52  <p>
53      Current user: <strong><?= h($currentUser) ?></strong>
54      | Role: <strong><?= h($currentRole) ?></strong>
55  </p>
56  <div class="nav-actions">
57      <a class="button-link" href="Lab12_files.php">Back to Files</a>
58      <a class="button-link" href="Lab12_upload_insecure.php">
59          Insecure Upload Demo
60      </a>
61  </div>
62  <section class="card">
63      <h2>Upload Securely</h2>
64      <p class="meta">
65          Allowed: PDF, JPG/JPEG, PNG | Maximum size: 2 MB
66      </p>
67      <form method="post"
68            action="Lab12_upload_secure.php"
69            enctype="multipart/form-data">
70          <input type="file"
71                 name="upload"
72                 accept=".pdf,.jpg,.jpeg,.png"
73                 required>
74          <input type="hidden"
75                 name="csrf_token"
76                 value="<?= h($_SESSION['csrf_token']) ?>">
77          <div class="actions">
78              <button type="submit">Upload Secure</button>
79          </div>
80      </form>
81  </section>
82  </body>
83  </html>
```

4.6 Lab12_upload_secure.php สำหรับตรวจ Size, Extension, MIME Type, เปลี่ยนชื่อไฟล์ และจัดเก็บนอก Web Root อย่างปลอดภัย (นักศึกษาสร้างเอง)

4.7 Lab12_files.php สำหรับแสดงรายการไฟล์ที่ผู้ใช้มีสิทธิ์เข้าถึงและเมนูสำหรับจัดการไฟล์ โดยมีคำสั่ง ดังนี้

```php
<?php
require_once 'Lab12_config.php';
require_login();
$message = $_GET['message'] ?? '';
if (is_admin($currentRole)) {
    $stmt = $conn->prepare(
        'SELECT id, original_name, mime_type, file_size,
                uploaded_by, storage_type, uploaded_at
         FROM uploaded_files
         ORDER BY id DESC'
    );
} else {
    $stmt = $conn->prepare(
        'SELECT id, original_name, mime_type, file_size,
                uploaded_by, storage_type, uploaded_at
         FROM uploaded_files
         WHERE uploaded_by = ?
         ORDER BY id DESC'
    );
    $stmt->bind_param('s', $currentUser);
}
$stmt->execute();
$result = $stmt->get_result();
?>
 <!doctype html>
 <html lang="en">
 <head>
     <meta charset="utf-8">
     <title>Lab12 - Secure File Upload</title>
     <style>
         body{
             font-family:Arial,sans-serif;
             max-width:900px;
             margin:32px auto;
             padding:0 16px;
             line-height:1.5
         }
         .card,.form-box,.notice{
             border:1px solid #ccc;
             border-radius:6px;
             padding:16px;
             margin-bottom:16px
         }
         .actions,.nav-actions{
             display:flex;
             gap:8px;
             margin-top:10px;
             align-items:center;
             flex-wrap:wrap
         }
```

```
        .actions form,.nav-actions form{margin:0}
        button,.button-link{
            display:inline-flex;
            align-items:center;
            justify-content:center;
            min-width:90px;
            height:36px;
            padding:0 12px;
            border:1px solid #888;
            border-radius:4px;
            background:#f5f5f5;
            color:#111;
            text-decoration:none;
            cursor:pointer;
            box-sizing:border-box;
            font:inherit
        }
        table{
            width:100%;
            border-collapse:collapse;
            margin-top:10px
        }
        th,td{
            border:1px solid #ccc;
            padding:8px;
            text-align:left;
            vertical-align:top
        }
        th{background:#f5f5f5}
        .meta{color:#666}
    </style>
</head>
```

```
<body>
<h1>Secure File Upload</h1>
<p>
    Current user: <strong><?= h($currentUser) ?></strong>
    | Role: <strong><?= h($currentRole) ?></strong>
</p>
<div class="nav-actions">
    <a class="button-link" href="Lab12_profile.php">My Profile</a>
    <a class="button-link" href="Lab12_upload_form.php">Upload Secure</a>
    <a class="button-link" href="Lab12_upload_insecure.php">
        Insecure Upload Demo
    </a>
    <?php if (is_admin($currentRole)): ?>
        <a class="button-link" href="Lab12_security_logs.php">
            Security Logs
        </a>
    <?php endif; ?>
    <form method="post" action="Lab12_logout.php">
        <input type="hidden"
               name="csrf_token"
               value="<?= h($_SESSION['csrf_token']) ?>">
        <button type="submit">Logout</button>
    </form>
</div>
 <?php if ($message !== ''): ?>
    <div class="notice"><?= h($message) ?></div>
 <?php endif; ?>
 <section class="card">
    <h2><?= is_admin($currentRole) ? 'All Uploaded Files' : 'My Uploaded Files' ?></h2>
    <table>
        <thead>
        <tr>
            <th>ID</th>
            <th>File</th>
            <th>MIME</th>
            <th>Size</th>
            <th>Owner</th>
            <th>Storage</th>
            <th>Uploaded At</th>
            <th>Action</th>
        </tr>
        </thead>
        <tbody>
        <?php if ($result->num_rows === 0): ?>
            <tr>
                <td colspan="8">No uploaded files.</td>
            </tr>
```

```
130             <?php else: ?>
131                 <?php while ($row = $result->fetch_assoc()): ?>
132                     <tr>
133                         <td><?= (int)$row['id'] ?></td>
134                         <td><?= h($row['original_name']) ?></td>
135                         <td><?= h($row['mime_type']) ?></td>
136                         <td><?= number_format((int)$row['file_size']) ?> bytes</td>
137                         <td><?= h($row['uploaded_by']) ?></td>
138                         <td><?= h($row['storage_type']) ?></td>
139                         <td><?= h($row['uploaded_at']) ?></td>
140                         <td>
141                             <?php if ($row['storage_type'] === 'secure'): ?>
142                                 <a class="button-link"
143                                    href="Lab12_download.php?id=<?= (int)$row['id'] ?>">
144                                     Download
145                                 </a>
146                             <?php else: ?>
147                                 Insecure / Web Root
148                             <?php endif; ?>
149                         </td>
150                     </tr>
151                 <?php endwhile; ?>
152             <?php endif; ?>
153             </tbody>
154         </table>
155     </section>
156     </body>
157     </html>
```

4.8 Lab12_download.php สำหรับดาวน์โหลดไฟล์ผ่าน Endpoint หลังตรวจ Role และ Ownership โดยมีคำสั่ง ดังนี้

```
1   <?php
2   require_once 'Lab12_config.php';
3   require_login();
4   $id = filter_input(INPUT_GET, 'id', FILTER_VALIDATE_INT);
5   if (!$id) {
6       http_response_code(400);
7       exit('Invalid request.');
8   }
9   $stmt = $conn->prepare(
10      'SELECT id, original_name, stored_name,
11              mime_type, file_size, uploaded_by, storage_type
12       FROM uploaded_files
13       WHERE id = ?'
14  );
15  $stmt->bind_param('i', $id);
16  $stmt->execute();
17  $file = $stmt->get_result()->fetch_assoc();
```

```php
if (!$file) {
    http_response_code(404);
    exit('File not found.');
}
if ($file['storage_type'] !== 'secure') {
    http_response_code(403);
    exit('This file is not stored in secure storage.');
}
/*
 * Server-side Authorization:
 * user -> only own file
 * admin -> any file
 */
if (!is_admin($currentRole) &&
    $file['uploaded_by'] !== $currentUser) {
    http_response_code(403);
    exit('Access denied.');
}
$storedName = basename($file['stored_name']);
$path = SECURE_UPLOAD_DIR . '/' . $storedName;
if (!is_file($path)) {
    http_response_code(404);
    exit('Stored file not found.');
}
 security_log(
     $conn,
     $currentUser,
     'FILE_DOWNLOAD',
     'SUCCESS',
     'Downloaded file id=' . $id
 );
 header('Content-Type: ' . $file['mime_type']);
 header('Content-Length: ' . filesize($path));
 header(
     "Content-Disposition: attachment; filename*=UTF-8''" .
     rawurlencode($file['original_name'])
 );
 header('X-Content-Type-Options: nosniff');
 readfile($path);
 exit;
```

4.9 Lab12_profile.php สำหรับแก้ไข Profile ของผู้ใช้และบันทึก PROFILE_UPDATE โดยมีคำสั่ง ดังนี้

```php
<?php
require_once 'Lab12_config.php';
require_login();
$message = '';
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    verify_csrf_token();
    $displayName = trim($_POST['display_name'] ?? '');
    $email = trim($_POST['email'] ?? '');
    if (
        $displayName === '' ||
        text_length($displayName) > 100 ||
        !filter_var($email, FILTER_VALIDATE_EMAIL) ||
        strlen($email) > 150
    ) {
        http_response_code(400);
        exit('Invalid request.');
    }
    $stmt = $conn->prepare(
        'UPDATE user_profiles
         SET display_name = ?, email = ?
         WHERE username = ?'
    );
     $stmt->bind_param(
         'sss',
         $displayName,
         $email,
         $currentUser
     );
     $stmt->execute();
     security_log(
         $conn,
         $currentUser,
         'PROFILE_UPDATE',
         'SUCCESS',
         'Profile updated'
     );
     $message = 'Profile updated.';
}
$stmt = $conn->prepare(
    'SELECT username, display_name, email
     FROM user_profiles
     WHERE username = ?'
);
$stmt->bind_param('s', $currentUser);
$stmt->execute();
$profile = $stmt->get_result()->fetch_assoc();
```

```php
if (!$profile) {
    http_response_code(404);
    exit('Profile not found.');
}
?>
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Lab12 - My Profile</title>
    <style>
        body{
            font-family:Arial,sans-serif;
            max-width:900px;
            margin:32px auto;
            padding:0 16px;
            line-height:1.5
        }
        .card,.notice{
            border:1px solid #ccc;
            border-radius:6px;
            padding:16px;
            margin-bottom:16px
        }
        label{
            display:block;
            font-weight:bold;
            margin-top:10px
        }
        input[type=text],
        input[type=email]{
            width:100%;
            max-width:500px;
            box-sizing:border-box;
            padding:8px
        }
```

```
        .actions,.nav-actions{
            display:flex;
            gap:8px;
            margin-top:12px;
            align-items:center;
            flex-wrap:wrap
        }
        button,.button-link{
            display:inline-flex;
            align-items:center;
            justify-content:center;
            min-width:90px;
            height:36px;
            padding:0 12px;
            border:1px solid #888;
            border-radius:4px;
            background:#f5f5f5;
            color:#111;
            text-decoration:none;
            cursor:pointer;
            box-sizing:border-box;
            font:inherit
        }
    </style>
</head>
<body>
<h1>My Profile</h1>
<p>
    Current user: <strong><?= h($currentUser) ?></strong>
    | Role: <strong><?= h($currentRole) ?></strong>
</p>
<div class="nav-actions">
    <a class="button-link" href="Lab12_files.php">Back to Files</a>
</div>
<?php if ($message !== ''): ?>
    <div class="notice"><?= h($message) ?></div>
<?php endif; ?>
<section class="card">
    <form method="post">
        <label for="display_name">Display Name</label>
        <input type="text" name="display_name" id="display_name"
               maxlength="100"
               value="<?= h($profile['display_name']) ?>"
               required>
        <label for="email">Email</label>
        <input type="email" name="email" id="email"
               maxlength="150" value="<?= h($profile['email']) ?>"
               required>
        <input type="hidden" name="csrf_token"
               value="<?= h($_SESSION['csrf_token']) ?>">
        <div class="actions">
            <button type="submit">Update Profile</button>
            <a class="button-link" href="Lab12_files.php">Cancel</a>
        </div>
    </form>
</section>
</body>
</html>
```

4.10 Lab12_security_logs.php เป็นหน้าเฉพาะ Admin สำหรับตรวจสอบ Security Log ของระบบ โดยมีคำสั่ง ดังนี้

```php
<?php
require_once 'Lab12_config.php';
require_login();
if (!is_admin($currentRole)) {
    http_response_code(403);
    exit('Access denied.');
}
$result = $conn->query(
    'SELECT id, username, event_type, status,
            ip_address, details, created_at
     FROM security_logs
     ORDER BY id DESC
     LIMIT 100'
);
?>
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Lab12 - Security Logs</title>
    <style>
        body{
            font-family:Arial,sans-serif;
            max-width:1100px;
            margin:32px auto;
            padding:0 16px;
            line-height:1.5
        }
        .nav-actions{
            display:flex;
            gap:8px;
            margin:12px 0 20px;
            align-items:center;
            flex-wrap:wrap
        }
```

```
        .button-link{
            display:inline-flex;
            align-items:center;
            justify-content:center;
            min-width:90px;
            height:36px;
            padding:0 12px;
            border:1px solid #888;
            border-radius:4px;
            background:#f5f5f5;
            color:#111;
            text-decoration:none;
            box-sizing:border-box;
            font:inherit
        }
        table{
            width:100%;
            border-collapse:collapse
        }
        th,td{
            border:1px solid #ccc;
            padding:8px;
            text-align:left;
            vertical-align:top
        }
        th{background:#f5f5f5}
    </style>
</head>
<body>
<h1>Security Logs</h1>
<p>
    Current user: <strong><?= h($currentUser) ?></strong>
    | Role: <strong><?= h($currentRole) ?></strong>
</p>
<div class="nav-actions">
    <a class="button-link" href="Lab12_files.php">Back to Files</a>
</div>
<table>
    <thead>
    <tr>
        <th>ID</th>
        <th>User</th>
        <th>Event</th>
        <th>Status</th>
        <th>IP</th>
        <th>Details</th>
        <th>Time</th>
    </tr>
    </thead>
```

```
85      <tbody>
86      <?php if ($result->num_rows === 0): ?>
87          <tr>
88              <td colspan="7">No security logs.</td>
89          </tr>
90      <?php else: ?>
91          <?php while ($row = $result->fetch_assoc()): ?>
92              <tr>
93                  <td><?= (int)$row['id'] ?></td>
94                  <td><?= h($row['username']) ?></td>
95                  <td><?= h($row['event_type']) ?></td>
96                  <td><?= h($row['status']) ?></td>
97                  <td><?= h($row['ip_address']) ?></td>
98                  <td><?= h($row['details']) ?></td>
99                  <td><?= h($row['created_at']) ?></td>
100             </tr>
101         <?php endwhile; ?>
102     <?php endif; ?>
103     </tbody>
104 </table>
105 </body>
106 </html>
```

งานที่ 1: ทดสอบ Login Log

งานที่ 1.1: ทดสอบ Login และ Role ของผู้ใช้

1) เปิด http://localhost:8080/Lab12/Lab12_login.php แล้ว Capture หน้าจอ

2) จากนั้นให้ Login ด้วย Username/Password ที่ไม่ถูกต้อง 1 ครั้ง แล้ว Capture หน้าจอ

3) จากนั้นให้ Login ด้วย student01 / Student01! แล้ว Capture หน้าจอ

งานที่ 2 ทดสอบ Security Logging

งานที่ 2.1 ทดสอบ Security Log สำหรับการแก้ไขข้อมูล

1) Login เป็น student01 แล้ว กด ปุ่ม My Profile

2) เปลี่ยน Display Name หรือ Email แล้วกด Update Profile

ตัวอย่าง Display Name: Student 01_test และE-mail: student01_test@example.com

Capture ผลลัพธ์ และ ฐานข้อมูล ตาราง user_profiles

3) ให้ Log out ออกจาก student01

งานที่ 2.2 ทดสอบดู Security Log

1) จากนั้นให้ Login เป็น admin01 / Admin01! Capture ผลลัพธ์หน้าจอ

2) จากนั้นกดปุ่ม Security Logs และ Capture รายการ LOGIN_FAILED รายการ LOGIN_SUCCESS และ รายการ PROFILE_UPDATE

งานที่ 3. ทดสอบ Upload ไฟล์

งานที่ 3.1 ทดสอบ Upload ไฟล์ที่ไม่เหมาะสม ด้วย Lab12_upload_insecure.php

1) ให้ Login เป็น admin01 / Admin01! จากนั้นกดที่ปุ่ม Insecure Upload Demo แล้ว Capture หน้าจอ
2) จากอัปโหลดไฟล์ malicious_demo.php (ไฟล์ที่เตรียมไว้ให้) แล้ว Capture หน้าจอ เมื่อกด Upload แล้ว
3) จาก เปิด Browser Tab ใหม่ แล้วใส่ URL http://localhost:8080/Lab12/uploads_insecure/malicious_demo.php

งานที่ 3.2 ทดสอบไฟล์ที่ไม่เหมาะสม ด้วย Lab12_upload_form.php

1) กดที่ปุ่ม Secure Upload แล้ว Capture หน้าจอ
2) ให้อัปโหลด malicious_demo.php แล้ว Capture หน้าจอผลลัพธ์
3) คัดลอก malicious_demo.php แล้วเปลี่ยนชื่อเป็น malicious_demo.jpg จากนั้นอัปโหลดอีกครั้ง แล้ว Capture หน้าจอผลลัพธ์
4) ลองอัปโหลดไฟล์ที่มีขนาดมากกว่า 2 MB ≈ 2,048 KB แล้ว Capture หน้าจอผลลัพธ์
5) จากนั้นกลับไปเพื่อตรวจ Security Log แล้ว Capture หน้าจอผลลัพธ์

งานที่ 3.3 ทดสอบ Upload ไฟล์ที่ถูกต้อง

1) ให้ Login เป็น student01 จากนั้น กดที่ปุ่ม Secure Upload
2) จากนั้นอัปโหลดไฟล์ PDF หรือ JPG/PNG ที่มีขนาดไม่เกิน 2 MB แล้ว Capture หน้าจอผลลัพธ์
3) ให้ไปที่ตาราง uploaded_files ใน phpMyAdmin แล้ว Capture หน้าจอผลลัพธ์
4) จากนั้นตรวจโฟลเดอร์ C:\dbwebsec-lab\uploads_lab12 แล้ว Capture ไฟล์ที่อยู่ในโฟลเดอร์ และเปรียบเทียบชื่อไฟล์จริงกับ original_name ใน Database
5) จากนั้นกลับไปเพื่อตรวจ Security Log แล้ว Capture หน้าจอผลลัพธ์

งานที่ 3.4 ทดสอบการอนุญาตการดาวน์โหลด

1) เข้าสู่ระบบเป็น student01 แล้ว กดที่ปุ่ม Secure Upload จากนั้นอัปโหลดไฟล์ PDF หรือ JPG/PNG ที่มีขนาดไม่เกิน 2 MB แล้ว Capture หน้าจอผลลัพธ์แล้วจดค่า id ของไฟล์
2) ออกจากระบบแล้ว เข้าสู่ระบบเป็น student02

3) ให้แก้ URL http://localhost:8080/Lab12/Lab12_download.php?id=... ให้ใช้ id ของไฟล์ student01 แล้ว Capture หน้าจอผลลัพธ์

4) จากนั้นเข้าสู่ระบบที่ admin01 แล้วเปิด URL: http://localhost:8080/Lab12/Lab12_download.php?id=... เดิมอีกครั้ง

